

Perancangan dan Implementasi Protokol Keamanan AAA pada Sistem Informasi Seekem

Design and Implementation of AAA Security Protocol in the Seekem Information System

Muhammad Abyan Putra Wibowo¹, Muhammad Agung Rizkiansyah¹, and Muhammad Chalied Al Walid¹

¹Departemen Ilmu Komputer, Fakultas Matematika dan Ilmu Pengetahuan Alam, IPB University, Bogor 16680

Ringkasan

Abstrak. Seekem merupakan sistem informasi pelaporan dan pencarian barang hilang yang digunakan oleh sivitas akademika IPB University. Aplikasi ini mengelola data identitas pengguna (NIM, nomor telepon) dan memfasilitasi proses persetujuan klaim barang yang rentan terhadap manipulasi atau penyangkalan. Penelitian ini merancang dan mengimplementasikan kerangka keamanan berlapis pada Seekem berdasarkan protokol Autentikasi, Otorisasi, dan Akuntansi (AAA) yang diperkuat dengan enkripsi simetris dan tanda tangan digital. Autentikasi menggunakan *hashing* kata sandi bcrypt dan manajemen sesi berbasis JSON Web Token (JWT). Otorisasi menerapkan kendali akses berbasis peran (RBAC) dengan pemisahan akses antara entitas Admin dan Civitas (mahasiswa), serta perlindungan terhadap kerentanan *Insecure Direct Object Reference* (IDOR) pada klaim pengguna. Akuntansi dilakukan dengan merekam jejak audit untuk setiap peristiwa kritis seperti persetujuan klaim dan pencatatan akses ilegal. Enkripsi tingkat kolom menggunakan AES-256-CBC melindungi Data Identitas Pribadi (PII) berupa NIM dan nomor telepon dari kebocoran basis data, sedangkan tanda tangan digital berbasis RSA memberikan jaminan non-repudiasi pada persetujuan klaim. Seluruh komunikasi antara klien (React) dan *backend* (FastAPI) diamankan melalui HTTPS (TLS 1.2+). Pengujian integrasi memverifikasi skenario keberhasilan masuk, kedaluwarsa token, penolakan akses lintas peran, mitigasi IDOR, serta akuntansi log. Hasil pengujian menunjukkan bahwa arsitektur yang diimplementasikan berhasil memenuhi standar keamanan untuk kerahasiaan, integritas, dan akuntabilitas.

Kata kunci. AES-256-CBC, autentikasi, enkripsi kolom, keamanan informasi, otorisasi, pencatatan log, RSA, sistem informasi

Abstract

Abstract. Seekem is an information system for reporting and searching lost items used by the IPB University academic community. The application manages user identity data (NIM, phone number) and facilitates item claim approval processes that are vulnerable to manipulation or repudiation. This paper designs and implements a multi-layered security framework for Seekem based on the Authentication, Authorization, and Accounting (AAA) protocol, reinforced with symmetric encryption and digital signatures. Authentication uses bcrypt password hashing and session management based on JSON Web Tokens (JWT). Authorization implements Role-Based Access Control (RBAC) separating Admin and Civitas (student) entities, as well as protection against Insecure Direct Object Reference (IDOR) vulnerabilities on user claims. Accounting is performed by recording audit trails for critical events such as claim approvals and logging illegal access attempts. Column-level encryption using AES-256-CBC protects Personally Identifiable Information (PII) such as NIM and phone numbers from database leaks, while RSA-based digital signatures provide non-repudiation guarantees for claim approvals. All communication between the client (React)

and backend (FastAPI) is secured via HTTPS (TLS 1.2+). Integration testing verified successful login scenarios, token expiration, cross-role access denial, IDOR mitigation, and log accounting. The testing results indicate that the implemented architecture successfully meets the security standards for confidentiality, integrity, and accountability.

Keywords. AES-256-CBC, authentication, authorization, column-level encryption, information security, logging, RSA, information system

1 PENDAHULUAN

Sistem informasi berbasis web yang memfasilitasi pelaporan dan pencarian barang hilang (*lost and found*) memiliki urgensi yang tinggi di lingkungan perguruan tinggi, mengingat pencatatan manual seringkali tidak efisien dan rentan terhadap hilangnya informasi (Al Ghiffari dan Prakosawati 2024). Merespons kebutuhan tersebut di lingkungan IPB University, kami mengembangkan Seekem, sebuah platform yang memungkinkan mahasiswa (Civitas) untuk melaporkan barang yang ditemukan atau hilang serta melakukan pengajuan klaim, sementara entitas Admin bertugas memverifikasi dan menyetujui klaim tersebut. Dalam beroperasi, sistem yang kami bangun ini mengelola Data Identitas Pribadi (PII) pengguna, meliputi Nomor Induk Mahasiswa (NIM) dan nomor telepon seluler, beserta kredensial autentikasi.

Sebagai pengembang, kami mengidentifikasi bahwa arsitektur sistem interaktif dengan multi-peran seperti Seekem sangat rentan terhadap ancaman keamanan siber apabila tidak dibekali mekanisme pertahanan *Security by Design*. Pengelolaan kata sandi tanpa perlindungan *hashing* akan berakibat fatal saat menghadapi serangan *brute force*. Selain itu, apabila otorisasi tidak divalidasi secara presisi, pengguna dapat dengan mudah memanipulasi data pengguna lain melalui eksploitasi *Insecure Direct Object Reference* (IDOR) atau mengelevasi hak akses menjadi Admin. Oleh karena itu, kami menerapkan *Role-Based Access Control* (RBAC) yang terbukti esensial dalam membatasi akses pada pangkalan data (Sahyudi dan Susanto 2024). Di samping itu, perlindungan privasi menuntut adanya enkripsi agar kebocoran basis data tidak langsung mengekspos identitas pengguna, serta dibutuhkan mekanisme audit (*accounting*) untuk mencegah konflik dari penyangkalan tindakan (klaim palsu).

Untuk mengatasi berbagai kerentanan tersebut, penelitian ini merancang dan mengimplementasikan protokol keamanan komprehensif yang bertumpu pada kerangka AAA (*Authentication, Authorization, Accounting*) pada ekosistem Seekem. Pada aspek autentikasi, kami memanfaatkan *hashing* bcrypt yang adaptif dipadukan dengan manajemen sesi *stateless* berbasis JSON Web Token (JWT), yakni standar mutakhir untuk pertukaran klaim pada aplikasi web (Mahindrakar dan Puji 2020). Pada aspek otorisasi, kami mengintegrasikan RBAC secara ketat yang dikombinasikan dengan validasi kepemilikan data guna memitigasi celah IDOR. Akuntansi sistem direalisasikan melalui *audit logging* pada setiap peristiwa krusial. Sebagai lapisan pertahanan data tingkat lanjut, kami mengimplementasikan algoritma enkripsi AES-256-CBC untuk menyandikan kolom PII, serta memberdayakan kunci asimetris RSA sebagai tanda tangan digital guna memberikan jaminan nirpenyangkalan (*non-repudiation*) pada setiap transaksi persetujuan klaim.

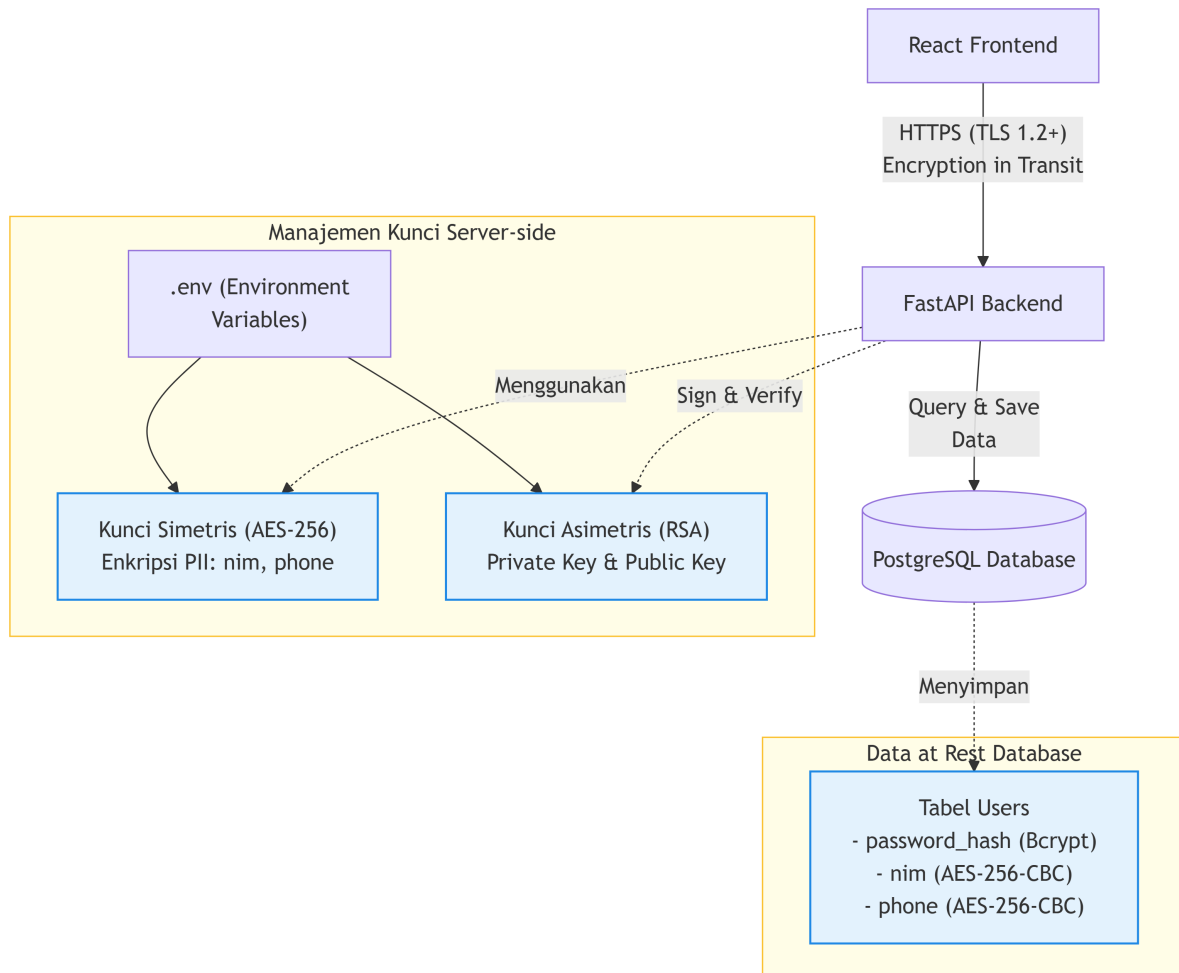
2 METODE

2.1 Arsitektur Sistem dan Keamanan

Sistem informasi Seekem dibangun dengan pemisahan antar lapisan (N-tier architecture). Sisi klien atau *frontend* dikembangkan menggunakan *framework* React. *Backend* menggunakan FastAPI berbasis Python yang menyediakan layanan REST API. Basis data yang digunakan adalah PostgreSQL. Seluruh komunikasi antarkomponen dikonfigurasi melalui protokol HTTPS

(TLS 1.2+) untuk menjamin kerahasiaan data selama masa transmisi (*Encryption in Transit*), melindungi token autentikasi dan data pengguna dari serangan *Man-in-the-Middle* (MitM).

Arsitektur manajemen kunci juga dirancang terpisah berdasarkan fungsinya. Kunci Simetris (AES-256) untuk enkripsi data identitas pribadi (PII) disimpan aman sebagai variabel lingkungan (`.env`) pada server. Sedangkan Kunci Asimetris (RSA) untuk *digital signature* dipisahkan ke dalam sepasang *Private Key* (disimpan di server) dan *Public Key* yang diverifikasi secara mandiri.



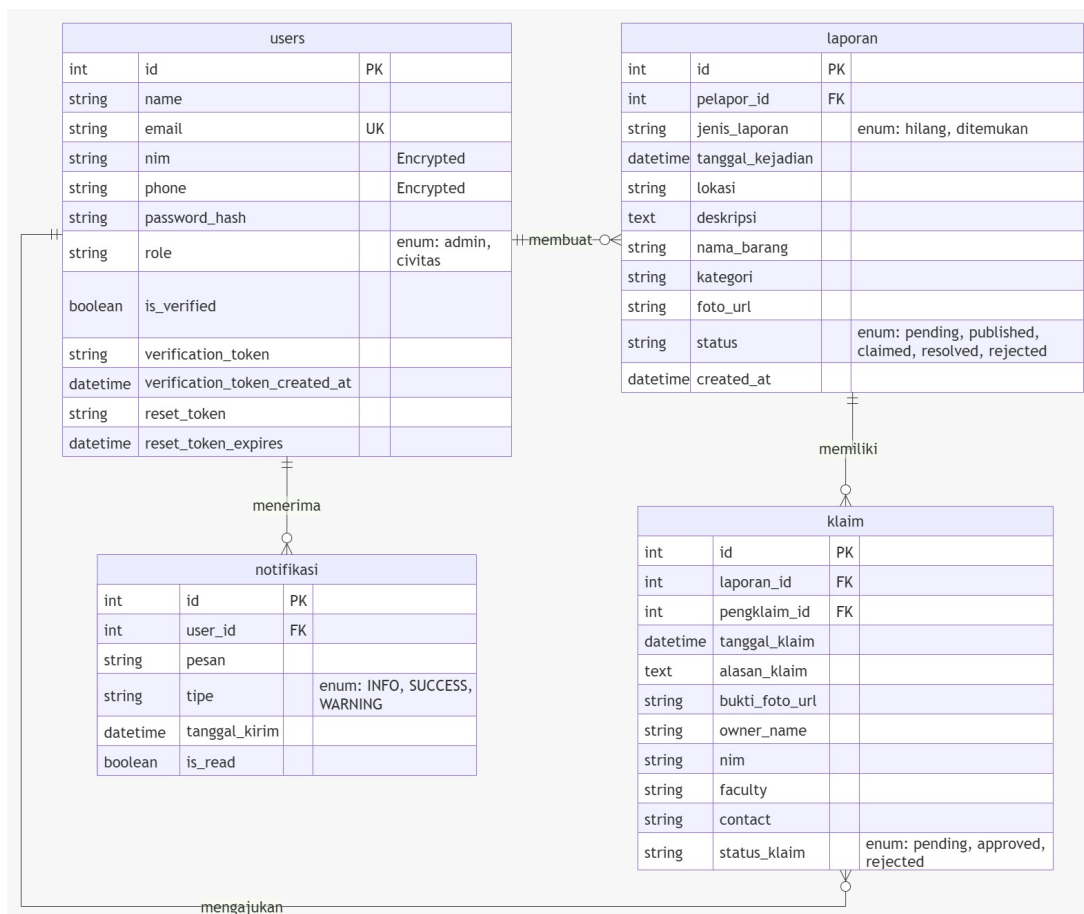
Gambar 1: Diagram Topologi Jaringan & Komponen Seekem

2.2 Pemodelan Ancaman dan Desain Kontrol Keamanan

Pemodelan ancaman yang dihadapi Seekem berfokus pada potensi manipulasi klaim dan pencurian data sensitif. Kontrol keamanan didesain berdasarkan tiga pilar utama AAA, yang dijabarkan pada Tabel 1.

2.3 Prosedur Uji Integrasi

Rencana pengujian (*Testing Plan*) difokuskan pada verifikasi fungsi-fungsi keamanan. Terdapat beberapa skenario yang wajib lulus saat dilakukan uji integrasi: 1) Login dengan kredensial sah, gagal, dan kedaluwarsa JWT; 2) Uji coba akses dari *Civitas* ke *endpoint* spesifik milik *Admin*; 3) Eksploitasi tiruan untuk menguji ketahanan terhadap kerentanan IDOR saat *Civitas A* mencoba



Gambar 2: Entity Relationship Diagram (ERD) Basis Data Seekem

Tabel 1: Pemetaan fungsi keamanan pada Sistem Seekem

Domain	Kontrol Keamanan
<i>Authentication</i> (Otentikasi)	Hashing <i>password</i> menggunakan Bcrypt dengan <i>salt</i> unik; JWT untuk validasi kedaluwarsa (<i>expiration</i>); fitur <i>reset password</i> .
<i>Authorization</i> (Otorisasi)	RBAC untuk pemisahan hak akses Admin dan Civitas ; proteksi pencegahan <i>Insecure Direct Object Reference</i> (IDOR) pada perubahan status klaim.
<i>Accounting</i> (Audit)	Merekam jejak audit di setiap klaim yang disetujui (<i>claim_approved</i>); pencatatan upaya akses ilegal (<i>Authorization fail</i>).
<i>Data at Rest</i>	Enkripsi kolom dengan algoritma AES-256-CBC pada <code>users.nim</code> dan <code>users.phone</code> ; <i>password</i> tidak disimpan dalam <i>plaintext</i> .
<i>Non-Repudiation</i>	Implementasi tanda tangan digital dengan RSA pada persetujuan klaim barang.

menyetujui klaim milik *Civitas B*; 4) Verifikasi keberhasilan perekaman log pada pangkalan data apabila sebuah klaim di-approve.

3 HASIL DAN PEMBAHASAN

3.1 Implementasi Autentikasi dan Hashing Sandi

Sistem autentikasi Seekem memanfaatkan bcrypt untuk menyimpan *password*. Penggunaan bcrypt dipilih karena sifatnya yang mampu menghasilkan *salt* unik untuk tiap iterasi sehingga secara efektif memitigasi serangan berbasis kamus (*rainbow tables*). Kode *backend* tidak pernah menangani atau menyimpan kata sandi pengguna dalam bentuk *plaintext*. Pada tahapan masuk aplikasi (login), FastAPI akan memberikan keluaran JSON Web Token (JWT) yang didesain *stateless*. Masa berlaku (*expiration*) token telah dikonfigurasi untuk mencegah pemanfaatan token curian yang tertinggal. Selain proses login, Seekem memfasilitasi penggantian kata sandi dengan token *reset* yang memiliki batasan umur singkat.

3.2 Implementasi Otorisasi (RBAC & IDOR Protection)

Fungsi otorisasi dilakukan di level *endpoint* dan level sumber daya (objek data). Lapisan pertama membedakan *Role* dari entitas pengguna yang terenkapsulasi dalam *payload* JWT. Fungsi ini memeriksa apakah nilai *role* pemanggil API memiliki kecocokan dengan peran yang disyaratkan oleh sebuah *endpoint*. Misalnya, *endpoint* `/approve_klaim` wajib memverifikasi bahwa token tersebut milik Admin. Jika seorang *Civitas* mencoba mengirimkan *request* ke *endpoint* tersebut, sistem akan langsung mengembalikan penolakan HTTP 403 *Forbidden*.

Lapisan kedua diterapkan melalui logika aplikasi untuk menangkal *Insecure Direct Object Reference* (IDOR). Seekem memvalidasi kepemilikan entitas (seperti laporan dan klaim) dengan mencocokkan identitas pada token dengan parameter *ID* pengguna di basis data sebelum melakukan modifikasi atau penghapusan.

```
1 # Cuplikan konsep mitigasi IDOR pada endpoint Civitas
2 def update_klaim(db: Session, klaim_id: int, user_id: int):
3     klaim = db.query(Klaim).filter(Klaim.id == klaim_id).first()
4     if klaim.pengklaim_id != user_id:
5         raise HTTPException(
6             status_code=403,
7             detail="Akses Ditolak: Anda tidak berhak mengubah klaim milik pengguna
8             lain."
9         )
10    # Proses update dilanjutkan...
```

Kode 1: Konsep pemeriksaan kepemilikan untuk mencegah kerentanan IDOR

3.3 Pencatatan Audit (Accounting) dan Notifikasi

Prinsip dasar dari komponen akuntansi adalah akuntabilitas tindakan pengguna dalam sistem. Pada setiap klaim barang yang disetujui (status *Approved*), sistem membangkitkan *event* untuk menyisipkan rekam jejak (*audit log*). Entri log memuat secara jelas identitas aktor (*user_id* Admin atau sistem), tipe aksi (*claim_approved*), dan waktu kejadian yang spesifik (*timestamp*). Log ini sangat berguna untuk proses forensik pascainsiden maupun mitigasi kesalahan operasional. Seekem juga mencatat upaya eksploitasi otorisasi yang gagal ke dalam log peringatan keamanan sistem, untuk mengawasi apabila terjadi serangan penetrasi yang dilakukan secara berulang.

3.4 Enkripsi Data Identitas Pribadi (PII) dan Tanda Tangan Digital

Berdasarkan rancangan keamanan basis data (Data at Rest), atribut PII pada tabel **Users** yang terdiri dari Nomor Induk Mahasiswa (**nim**) dan nomor telepon seluler (**phone**) dienkripsi secara *inline* menggunakan algoritma AES-256 dalam mode CBC (Cipher Block Chaining). Algoritma simetris ini dipilih karena kemampuannya memproses enkripsi berkecepatan tinggi dengan tingkat keamanan bit yang masif, sehingga jika berkas basis data PostgreSQL jatuh ke tangan peretas, informasi pengenalan sivitas IPB tidak dapat diekstraksi tanpa *secret key* dari variabel lingkungan.

Sedangkan untuk menjamin bahwa proses **approve_klaim** sah dan tidak dapat disangkal di kemudian hari (*non-repudiation*), Seekem menerapkan *digital signature* berbasis RSA. Ketika transaksi **approve_klaim** terjadi, ringkasan transaksi dikanonikalisasi dan ditandatangani menggunakan *Private Key* RSA yang tersimpan di sisi server. Pembuktian (*verify*) integritas kemudian dikaitkan dengan *Public Key* yang dimiliki, memvalidasi keabsahan data tanpa bisa dipalsukan oleh entitas mana pun yang tidak memegang kunci privat.

3.5 Hasil Uji Integrasi

Berdasarkan dokumen Rencana Pengujian (*Testing Plan*) yang telah kami susun, kami melaksanakan serangkaian pengujian unit dan integrasi untuk memverifikasi ketahanan sistem terhadap ancaman yang dimodelkan. Hasil pengujian yang kami lakukan menunjukkan keberhasilan penuh atas seluruh skenario: 1. Kami memverifikasi bahwa sistem berhasil menolak masuknya kredensial yang tidak sah pada saat *login*, dan fungsi penanganan *token expiration* berjalan sesuai rancangan untuk mengamankan sesi lama. 2. Kami berhasil menggagalkan skenario eksploitasi akses lintas peran (*Cross-Role Access*), di mana sistem yang kami bangun secara konsisten memblokir eksekusi *endpoint approve_klaim* apabila diakses oleh pengguna bertipe Civitas. 3. Kami memastikan bahwa kerentanan IDOR pada proses pembaruan data telah teratasi. Hal ini dibuktikan melalui penolakan otomatis oleh sistem saat kami melakukan uji coba manipulasi, karena sistem selalu memverifikasi kecocokan antara **user_id** milik pemanggil dengan **pengklaim_id** yang terdaftar pada klaim terkait. 4. Pada evaluasi fungsi akuntansi, kami memvalidasi bahwa setiap skenario persetujuan (Approve) secara asinkron selalu sukses merekam entri *audit* ke pangkalan data tanpa pengecualian, sehingga menjamin tercapainya fungsionalitas akuntansi secara andal.

4 SIMPULAN

Penelitian ini sukses merancang dan mengimplementasikan protokol pengamanan menyeluruh pada sistem lost-and-found Seekem. Integrasi Authentication, Authorization, dan Accounting (AAA) telah memitigasi celah eksploitasi konvensional, terutama pembatasan akses berbasis peran (Admin dan Civitas) serta pencegahan celah IDOR. Penerapan kriptografi tingkat lanjut yang mencakup hashing Bcrypt untuk sandi, AES-256-CBC untuk kolom data sensitif (NIM, nomor telepon), dan penggunaan arsitektur RSA untuk tanda tangan digital pada transaksi persetujuan klaim berhasil memperkuat integritas data. Konfigurasi enkripsi pada saat transit melalui TLS (HTTPS) dan arsitektur *secure key management* memastikan data tetap rahasia. Keseluruhan fitur keamanan ini membentuk ekosistem aplikasi yang andal bagi sivitas IPB University.

UCAPAN TERIMA KASIH

Penulis menyampaikan terima kasih kepada seluruh anggota tim dan dosen pembimbing proyek akhir yang senantiasa mendukung jalannya perancangan sistem informasi Seekem di lingkungan IPB University.

Daftar Pustaka

- Al Ghiffari MZ, Prakosawati EE. 2024. Analisis Kinerja Petugas Lost and Found dalam Penanganan Bagasi Maskapai Citilink di Bandar Udara Internasional Juanda Surabaya. *Jurnal Manajemen Bisnis Digital Terkini*. 2(3):270–283. doi:10.61132/jumbidter.v2i3.667.
- Mahindrakar P, Pujeri U. 2020. Insights of JSON Web Token. *International Journal of Recent Technology and Engineering*. 8(6):1707–1710. doi:10.35940/ijrte.f7689.038620.
- Sahyudi M, Susanto ER. 2024. Analisis Implementasi Sistem Keamanan Basis Data Berbasis Role-Based Access Control (RBAC) pada Aplikasi Enterprise Resource Planning. *SATESI: Jurnal Sains Teknologi dan Sistem Informasi*. 5(1):105–116. doi:10.54259/satesi.v5i1.3997.